

ISO 27001:2022 & NIST CSF 2.0 Gap Analysis & Risk Remediation Report

Candidate / Author: Junior GRC Analyst (Portfolio Assessment)

Target Organization Scope: PaySecure Cloud Services India Pvt. Ltd. (AWS Cloud Infrastructure, EKS Clusters, Financial APIs, and PII Repositories)

Evaluated Frameworks: ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0, and Digital Personal Data Protection (DPDP) Act 2023

Assessment Date: October 2026

1. Executive Summary & Assessment Context

As part of my practical GRC portfolio training, I conducted a hands-on gap assessment for PaySecure Cloud Services—a cloud-native fintech platform hosted on AWS. My objective was to evaluate the company's security posture against **ISO/IEC 27001:2022 (Annex A)**, **NIST CSF 2.0**, and the **Indian DPDP Act 2023**, transitioning theoretical compliance requirements into an actionable risk assessment.

Across the 10 evaluated control scenarios:

- **Overall Compliance Score: 50.0%** across 9 applicable controls.
- **Control Breakdown:** 2 controls are Fully Implemented, 5 controls are Partially Implemented, and 2 controls are Not Implemented.
- **Scope Exclusions:** 1 control (ISO A.7.1 Physical Security) was formally excluded as it is inherited from AWS under the Shared Responsibility Model.

While the platform demonstrates strong baseline maturity in operational logging (A.8.15) and vulnerability management (A.8.8), I identified **two Critical-risk gaps** that require immediate remediation:

1. **Unencrypted Customer PII in Staging (A.8.12 / DPDP Act):** Non-production environments process real customer PII without data masking or automated Data Leakage Prevention (DLP).
2. **Unverified Disaster Recovery Failover (A.5.29 / NIST RC.RP-01):** Multi-region failover testing has not been executed in the past 12 months, creating SLA availability risks.

2. Compliance Metrics & Risk Profile

Table 1: Compliance Status Summary

Metric	Count	Percentage of Applicable Scope	Notes & Candidate Observations
Total Controls Evaluated	10	100%	Full scope across Cloud, IAM, Data Privacy, BCP, and DevSecOps.
Applicable Controls (SoA)	9	90.0%	Controls within direct operational and engineering boundary.
Excluded Controls (SoA)	1	10.0%	Inherited via AWS SOC 2 Type II / ISO 27001 certifications (A.7.1 Physical Security).
Fully Implemented	2	22.2%	Log streams to SIEM with WORM Object Lock & automated CVE scanning.
Partially Implemented	5	55.6%	IaC baselines, CLI MFA enforcement, K8s image signing, KMS key rotation, and SAST.
Not Implemented	2	22.2%	Staging PII data masking/DLP & Multi-region DR failover testing.

Overall Compliance Score	50.0%	—	Weighted calculation: Fully Implemented * 1.0) + (Partially Implemented * 0.5) / Total Applicable Controls
---------------------------------	--------------	---	--

Table 2: Inherent Risk Level Breakdown

Risk Level	Count	Target Timeline	Primary Focus Areas
CRITICAL	2	30 Days	Non-production PII Exposure (A.8.12) & Unverified DR Failover (A.5.29).
HIGH	4	30 to 60 Days	Manual AWS console setups (A.5.23), CLI MFA gaps (A.5.15), Unsigned K8s images (A.8.9), Manual SAST (A.8.28).
MEDIUM	1	60 Days	Default KMS service keys without Customer Managed Keys (CMK) (A.8.24).
LOW	3	90 Days / Maintain	SIEM logging (A.8.15), Container CVE scanning (A.8.8), Physical Security (A.7.1 - Inherited).

3. Detailed Audit Findings & Analysis

Finding 1: Non-Production PII Exposure & Missing DLP (Critical Risk)

- **Control Mapping:** ISO 27001:2022 A.8.12 | NIST CSF PR.DS-01 | DPDP Act 2023 Sec 8
- **Audited Condition:** Production database staging snapshots containing customer PII (PAN cards, phone numbers, transactional history) are cloned into non-production environments without data masking or tokenization.
- **My Analysis & Impact:** This practice directly violates Section 8 of the Indian DPDP Act 2023. If a staging environment or developer laptop is compromised, real customer data would be exposed, creating severe legal and regulatory liability.
- **Recommended Action:** Enforce dynamic schema-level data masking during database sync pipelines and enable AWS Macie to automatically scan S3 buckets for sensitive PII.

Finding 2: Unverified Disaster Recovery & Failover Procedures (Critical Risk)

- **Control Mapping:** ISO 27001:2022 A.5.29 | NIST CSF RC.RP-01
- **Audited Condition:** Multi-region database failover testing has not been executed or simulated within the last 12 months, and RTO/RPO metrics remain undocumented in operational contracts.
- **My Analysis & Impact:** Without regular disaster recovery drills, the platform cannot guarantee its 99.9% uptime SLA during an outage, risking extended service downtime during AWS regional disruptions.
- **Recommended Action:** Formally establish RTO (4 hours) and RPO (15 minutes) targets, document the BCP/DR runbook, and schedule a live multi-region failover drill.

Finding 3: AWS Administrative Access Without CLI/API MFA (High Risk)

- **Control Mapping:** ISO 27001:2022 A.5.15 | NIST CSF PR.AA-01
- **Audited Condition:** While web console access enforces MFA, programmatic access keys used via the AWS CLI and API do not enforce multi-factor authentication.
- **My Analysis & Impact:** Stolen developer credentials or leaked access keys could grant full administrative control over cloud resources without triggering an authentication challenge.
- **Recommended Action:** Implement IAM conditional access policies that restrict CLI and API actions unless authenticated with short-lived session tokens generated via TOTP or hardware MFA.

Finding 4: Unsigned Container Images in Kubernetes Production (High Risk)

- **Control Mapping:** ISO 27001:2022 A.8.9 | NIST CSF PR.PS-01
- **Audited Condition:** EKS Kubernetes clusters allow container deployments without cryptographic image signature verification.
- **My Analysis & Impact:** This opens up software supply chain risks, allowing unverified or potentially tampered container images to run in production namespaces.
- **Recommended Action:** Integrate Kyverno or Cosign admission controllers to enforce signature verification policies before any container image is deployed to EKS.

4. 30-60-90 Day Risk Remediation Strategy

Phase 1: Immediate Critical Risk Mitigation (0 - 30 Days)

- Deploy dynamic schema-level PII data masking on database staging snapshots
- Enforce mandatory TOTP/Hardware MFA on AWS CLI/API session credentials
- Conduct multi-region DB failover simulation and publish documented RTO/RPO targets

Phase 2: Architectural Guardrails & DevSecOps (31 - 60 Days)

- Convert manual AWS Console setups into Terraform IaC templates with GuardDuty
- Enforce Cosign/Kyverno image signature verification on EKS clusters
- Migrate AWS KMS keys to Customer Managed Keys (CMK) with 90-day rotation
- Embed SonarQube/Semgrep SAST scans into GitHub Actions build pipelines

Phase 3: Continuous Governance & Verification (61 - 90 Days)

- Set up automated compliance tracking via AWS Security Hub
- Conduct annual third-party review of AWS SOC 2 Type II audit reports
- Execute quarterly log retention and SIEM WORM Object Lock verification

5. Candidate Reflection & Lessons Learned

Performing this gap assessment gave me practical, hands-on experience in how information security governance operates in a real cloud environment:

1. **Bridging Technical Execution and Business Compliance:** I learned that technical practices (like database snapshotting or CLI access) directly affect legal and regulatory obligations like the DPDP Act 2023.
2. **Prioritizing Remediation Based on Inherent Risk:** Rather than giving engineering a flat list of issues, sorting findings into Critical, High, and Medium tiers allows teams to focus resources where exposure is highest.
3. **Collaborative Problem Solving:** Effective GRC isn't about blocking development—it's about partnering with DevOps, SecOps, and Engineering owners to build realistic, 30-60-90 day remediation paths.